

POST-QUANTUM CRYPTOGRAPHY

Assessment Report

Acme Corporation

100

Risk Score

33

Findings

6

Files Scanned

Scan date: 2026-03-22

CONFIDENTIAL

1. EXECUTIVE SUMMARY

IMMEDIATE ACTION REQUIRED. This assessment found **16 CRITICAL** and **9 HIGH** severity quantum-vulnerable cryptographic implementations. These algorithms will be broken by Shor's algorithm when cryptographically relevant quantum computers (CRQC) become available, estimated between 2030-2040.

The primary threat is **Harvest Now, Decrypt Later (HNDL)**: adversaries can intercept and store encrypted data today, then decrypt it once quantum computers are available. This makes key exchange migration (RSA, ECDH, DH) urgent even before CRQC exists.

2. COMPLIANCE STATUS

CNSA 2.0: NON-COMPLIANT

Algorithm	Status	Deadline	Findings	Action
RSA	NON-COMPLIANT	2030	6	ML-KEM-1024 (key exchange), ML-DSA-87 (s
ECDSA	NON-COMPLIANT	2035	5	ML-DSA-87
AES-128	NON-COMPLIANT	2030	2	AES-256
3DES	NON-COMPLIANT	2023	4	AES-256
SHA-1	NON-COMPLIANT	2023	1	SHA-384 or SHA-512
MD5	NON-COMPLIANT	2010	2	SHA-384
ECDH	NON-COMPLIANT	2030	2	ML-KEM-1024

NIST IR 8547: NON-COMPLIANT

Algorithm	Status	Deadline	Findings	Action
3DES	NON-COMPLIANT	2023	4	AES-256
SHA-1	NON-COMPLIANT	2023	1	SHA-256 or SHA-3
MD5	NON-COMPLIANT	2010	2	SHA-256
RSA	DEPRECATED	2030	6	ML-KEM (FIPS 203) / ML-DSA (FIPS 204)
ECDSA	DEPRECATED	2035	5	ML-DSA (FIPS 204)
AES-128	DEPRECATED	2030	2	AES-256
ECDH	DEPRECATED	2030	2	ML-KEM (FIPS 203)

PCI DSS 4.0: NON-COMPLIANT

Algorithm	Status	Deadline	Findings	Action
3DES	NON-COMPLIANT	2023	4	AES-128 or AES-256
SHA-1	NON-COMPLIANT	2023	1	SHA-256
MD5	NON-COMPLIANT	2010	2	SHA-256
RSA	DEPRECATED	2030	6	ML-KEM + ML-DSA
ECDSA	COMPLIANT	-	5	-
AES-128	COMPLIANT	-	2	-
ECDH	COMPLIANT	-	2	-

3. TOP FINDINGS

CRITICAL (16 findings)

ID	Algorithm	File	Line	Replacement
PQC-0001	RSA	api.js	5	ML-KEM-768 or ML-DSA-65
PQC-0002	DH/ECDH	api.js	14	Consult NIST PQC standards
PQC-0004	DH/ECDH	api.js	22	Consult NIST PQC standards
PQC-0005	RSA	app.py	12	ML-KEM-768 or ML-DSA-65
PQC-0006	ECDSA	app.py	22	ML-DSA-65
PQC-0007	ECDSA	app.py	23	ML-DSA-65
PQC-0008	ECDSA	app.py	24	ML-DSA-65
PQC-0016	RSA	crypto_utils.go	5	ML-KEM-768 or ML-DSA-65
PQC-0017	ECDSA	crypto_utils.go	6	ML-DSA-65
PQC-0018	ECDH	crypto_utils.go	7	ML-KEM-768

... and 6 more CRITICAL findings

HIGH (9 findings)

ID	Algorithm	File	Line	Replacement
PQC-0003	RSA/ECDSA	api.js	18	Consult NIST PQC standards
PQC-0010	3DES	app.py	27	AES-256-GCM
PQC-0012	3DES	app.py	29	AES-256-GCM
PQC-0014	MD5	app.py	34	SHA-256 or SHA-3
PQC-0015	MD5	app.py	35	SHA-256 or SHA-3
PQC-0019	3DES	crypto_utils.go	9	AES-256-GCM
PQC-0023	3DES	crypto_utils.go	22	AES-256-GCM
PQC-0024	Old TLS	nginx.conf	6	Consult NIST PQC standards
PQC-0025	Weak cipher	nginx.conf	7	Consult NIST PQC standards

MEDIUM (4 findings)

ID	Algorithm	File	Line	Replacement
PQC-0009	AES-128	app.py	26	AES-256
PQC-0011	AES-128	app.py	28	AES-256
PQC-0013	SHA-1	app.py	32	SHA-256 or SHA-3

4. RECOMMENDED MIGRATION ROADMAP

Phase 1: Immediate (0-3 months)

- Replace all RSA/DH key exchange with ML-KEM-768 hybrid (X25519+ML-KEM)
- Enable PQC key exchange in TLS 1.3 (Chrome/Cloudflare already support this)
- Upgrade AES-128 to AES-256 across all systems
- Remove MD5, SHA-1, DES, 3DES, RC4 from all codepaths

Phase 2: Short-term (3-12 months)

- Migrate RSA/ECDSA code signing to ML-DSA-65 (FIPS 204)
- Update SSH key exchange to sntrup761+x25519 (OpenSSH 9.0+)
- Replace ECDSA/Ed25519 certificates with ML-DSA when CA supports it
- Audit all JWT/JOSE signing for PQC compatibility

Phase 3: Medium-term (12-24 months)

- Complete certificate infrastructure migration to PQC
- Deploy PQC-enabled VPN (IPsec with ML-KEM via RFC 9370)
- Update S/MIME email encryption to PQC
- Migrate all code signing and firmware signing

Phase 4: Validation (Ongoing)

- Continuous PQC compliance monitoring via CI/CD (pqc-scanner)
- Regular certificate chain audits
- Track NIST algorithm health (monitor for cryptanalytic advances)
- Performance benchmarking of PQC vs classical implementations

5. EFFORT & COST ESTIMATES

Phase	Effort	Cost Range	Risk if Delayed
Key exchange (TLS/SSH)	2-4 weeks	\$15K-40K	HNDL attack exposure NOW
Certificate migration	4-8 weeks	\$30K-80K	Non-compliance by 2030
Code signing	2-4 weeks	\$10K-30K	Supply chain risk
Symmetric upgrade (AES)	1-2 weeks	\$5K-15K	Reduced security margin
CI/CD integration	1 week	\$5K-10K	Regression risk
Full validation	2-4 weeks	\$15K-40K	Audit failure risk
TOTAL	12-24 weeks	\$80K-215K	

Cost estimates assume a mid-size enterprise (50-200 developers, 10-50 services). Actual costs depend on codebase size, language diversity, and deployment complexity.

CONFIDENTIAL // Generated by Enigma pqc-scanner